

Firewalls

Network based Firewall:

Filter traffic by port number or application:

- Traditional vs NGFWs

Encrypt traffic:

- VPN between sites

Most firewalls can be layer 3 devices:

- Often lists on the ingress/egress of the network
- Network Address Translation (NAT)
- Dynamic routing

NGFWs:

The OSI application layer:

- Layer 7 firewall

Can be called different names:

- App layer gateway
- Stateful multilayer inspection
- Deep packet inspection

Requires some advanced decodes:

- Every packet must be analyzed, categorized, and a security decision determined

Ports and protocols:

Make forwarding decisions based on protocol (TCP or UDP) and port number:

- Tradition. Port based firewalls
- Add to an NGFW for additional security policy options

Based on destination protocol and port:

- Web server: tcp/80, tcp/443
- SSH server: tcp/22
- Microsoft RDP; tcp/3389
- DNS query; udp/53
- NTP: udp/123

Firewall rules:

A logical path:

- usually top to bottom

Can be very general or very specific:

- Specific rules are usually at the top

Implicit deny:

- Most firewalls include a deny at the bottom
 - Even if you didn't put one

Access control list (ACLs);

- Allow or disallow traffic
- Groupings of categories - source IP, destination IP, port numbers, time of day, application, etc.

Web server firewall ruleset



Rule Number	Remote IP	Remote Port	Local Port	Protocol	Action
1	All	Any	22	TCP	Allow
2	All	Any	80	TCP	Allow
3	All	Any	443	TCP	Allow
4	All	Any	3389	TCP	Allow
5	All	53	Any	UDP	Allow
6	All	123	Any	UDP	Allow
7	All			ICMP	Deny

<https://ProfessorMesser.com>

© 2023 Messer Studios, LLC

Screened subnet:

An additional layer of security between you and the internet:

- Public access to public resources
- Private data remains inaccessible

IPS rules:

Intrusion Prevention System(IPS):

- usually integrated with IPS

Different ways to find malicious traffic:

- Look at traffic as it passes by

Signature based:

- Look for a perfect match

Anomaly based;

- Build a baseline of what's normal
- Unusual traffic patterns flagged

You determine what happens when unwanted traffic appears:

- block, allow, send alert etc

Thousands of rules:

- or more

Rules can be customized by group:

- or as individual rules

This can time to find the right balance

Web filtering

Content filtering:

Control traffic based on data within the content:

- URL filtering, webs category filtering

Corporate control of outbound and inbound data:

- sensitive stuff

Control of inappropriate content:

- NSFW
- Parental controls

Protection against malware / virus

URL scanning:

Allow or restrict based on URL (Uniform Resource Locator):

- Also called a Uniform Resource Identifier
- Allow list/ block list

Managed by category:

- Auction, Hacking, malware, travel, recreation, etc

Can have limited control:

- URLs aren't the only way to surf

Often integrated into NGFW

Agent based:

Install client software on the users device:

- Usually managed from central console

Users can be located anywhere:

- The local agent makes the filtering decisions
- Always hands-on

Updates must be distributed too all agents:

- cloud based updated
- Update satus shown at the console

Procies;

- Sit between the users and the external network

Receives the user requests and sends the request on their behalf (the proxy)

Useful for caching information, access control, URL filtering, content scanning

Apps may need to know how to use the proxy

Some proxies are invisible or transparent

Forward proxy:

A centralized "internal proxy":

- Commonly used to protect and control user access to the internet

Block rules:

- Based on a specific URL

Category of site content:

- Usually divide into 50 different topics"
- Adult, gambling, gardening, educational etc

Different dispositions:

- Education allow
- Gambling blocked

Reputation:

Filter URLs based on perceived risk:

- A good rep is allowed, bad rep = blocked

Automated reputation:

- Sites are scanned and assigned a rep

Manual rep:

- Manually select reputation of a site

Add these dispositions to the URL filter:

- High risk: Block, trustworthy: allow

DNS filtering:

Before connecting to a website, get the IP address:

- Perform DNS lookup

DNS is updated with real time threat intelligence:

- Both commercial and public lists

Harmful sites are not resolved:

- no IP address = no connection

This works for any DNS lookup - not just web filtering

Operating system security

Active Directory:

A database of everything on the network:

- Computers, user accounts, printers, groups, and more
- Primarily windows based

Managed authentication:

- Users login using their AD creds

Centralized access control:

- Determine which users can access resources

Commonly used by the help desk:

- Reset passwords, add and remove accounts

Group policy;

- Manage the computers or users with Group policies:
 - Local and domain policies
 - Group Policy Management Editor (GPME)

A central console:

- Login scripts
- Network configurations
- Security parameters

Comprehensive control:

- Hundreds of configuration options

Security Enhancement Linux (SELinux):

Security patches for the Linux kernel:

- Adds mandatory access control (MAC) to Linux
- Linux traditionally uses Discretionary Access Control (DAC)

Limits application access;

- Least privilege
- A potential breach will have limited scope

Open source:

- Already included as an option with many linux distributions

Secure Protocols

Unencrypted network data:

Network traffic is important data:

- Everything must be protected

Some protocols aren't encrypted:

- All traffic sent in the clear

- Telnet, FTP, SMTP, IMAP

Verify with a packet capture:

- View everything sent over the network

Protocol selection:

Use a secure application. Protocol:

- Built in encryption

A secure protocol may not be available:

- This may be a dealbreaker

Port selection:

Secure and insecure application connections may be available'

- its common to run secure and insecure on different ports

HTTP and HTTPS:

- In the clear and encrypted web browsing
- HTTP: port 80 - in the clear BAD
- HTTPS; port 443 - GOOD

The port number does not guarantee security:

- confirm the security features are enabled
- Packet captures may be necessary

Transport method:

Don't rely on the application:

- Encrypt everything over the current network transport

802.11 Wireless:

- Open access port: No transport level encryption
- WPA3: all user data is encrypted

VPN:

- Creates an encrypted tunnel
- All traffic encrypted and protected
- Often requires third party services and software

Email Security

Email security challenges:

The protocols used to transfer emails include relatively few security checks:

- Its very easy to spoof an email

Spoofing happens all the time:

- Check your spam folder

The looks like it originated from somewhere you know but it probably didn't

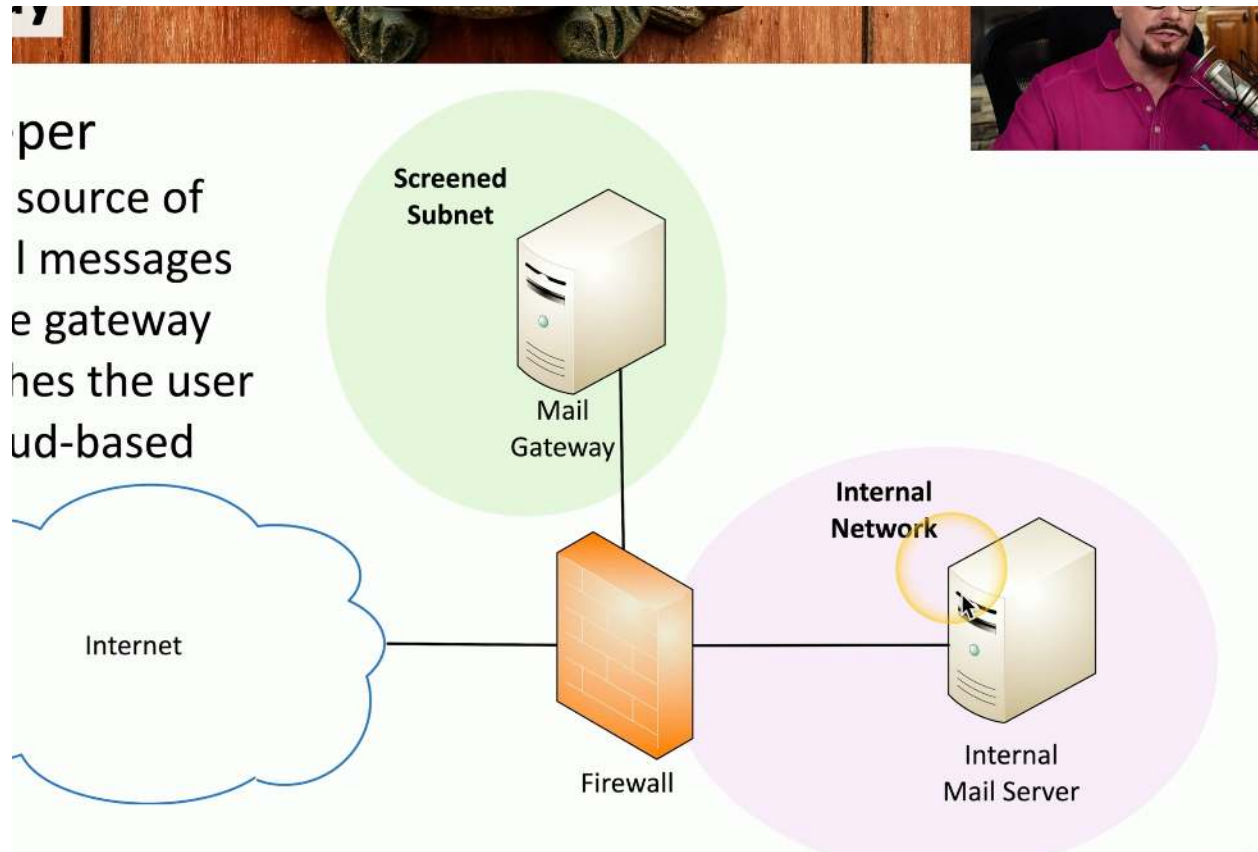
A reputable sender will configure email validation:

- Publicly available on the senders DNS server

Mail gateway:

The gatekeeper:

- Evaluates the source of inbound email messages
- Blocks it at the gateway before it reaches the user
- On site or cloud based



Sender Policy Framework (SPF):

SPF protocol:

- Sender configures a list of all servers authorized to send email for a domain

List of authorized mail servers are added to a DNS TXT record:

- Receiving mail servers perform a check to see if incoming mail really did come from an authorized host

Domain Keys Identified Mail (DKIM):

A mail sever digitally signs all outgoing mail:

- The public key is the DKIM TXT record

DMARC:

Domain-based Message Authentication, Reporting and Conformance:

- An extension of SPF and DKIM

The domain owner decided what receiving email servers should do with emails not validating using SPF and DKIM:

- That policy is written into a DNS TXT record
- Accept all, send to spam, or reject the email

Compliance reports are sent to the email administration:

- The domain owner can see how the emails are received

Monitoring Data

FIM (File Integrity Monitoring):

Some files change all the time:

- Some files should never change

Monitor important operating system and application files:

- Identify when changes occur

Windows - SFC (System File Checker)

Linux - Tripwire

Many host based IPS options

Data Loss Prevention (DLP):

Where's your data?

- Social security numbs, credit card number

Stop the data before the attacker gets it

So many sources and destinations;

- Often requires multiple solutions in different places

On your computer:

- Data in use
- Endpoint DLP

On your network:

- Data in motion

On your server:

- Data at rest

USB blocking:

DLP on a workstation:

- Allow or deny certain tasks

November 2008 - US DOD:

- Worm Virus agent.btz and replicates using USB storage

- Bans removable flash media and storage devices

All devices had to be updated;

- Local DLP agent handled USB blocking

Ban was lifted in February 2010

Cloud based DLP:

Located between users and internet:

- Watch every byte of network traffic
- No hardware, no software

Block custom defined data strings:

- Unique data for your organization

Manage access to URLs:

- prevent file transfers to cloud storage

Block viruses and malware:

- Anything traversing the network

DLP and email:

Email continues to be the most critical vector:

- Inbound threats, outbound data loss

Check every email inbound and outbound:

- internal system or cloud based

Inbound:

- Block keywords, identify imposters, quarantine email messages

Outbound:

- Fake wire transfer, W2 transmission, employee information

Emailing a spreadsheet template:

- November 2016
- Boeing employ emails spouse a spreadsheet to use as a template

Contained the personal information. Of 36000 Boeing employees:

- In the hidden columns
- Social security numbers DOB etc

Boeing sells its own DLP software:

- But only uses it for classified work

Endpoint Security

The users access:

- Applications and data

Stop the attackers:

- Inbound and outbound traffic

Many different platforms:

- Mobil, desktop

Protections is multi faceted:

- Defense in depth

Edge vs access control:

Control at the edge:

- Your internet link
- Managed primarily through firewall rules
- firewall rules rarely change

Access control:

- Control form wherever you are:
 - Inside or outside
- Access can be based on many rules:
 - By user group, location, application, etc
- Access can be easily revoked or changed:
 - Change your security posture at any time

Posture Assessment:

You can't trust everyones computer:

- BYOD
- Malware infection / missing antimalware
- Unauthorized apps

Before connecting to the network, perform a health check:

- Is it trusted?
- Is it running antivirus
- Are corporate apps installed
- Is it a mobile device etc

Persistent agents:

- Permanently installed onto a system
- Periodic updates may be required

Dissolvable agents:

- No installation is required
- Runs during the posture assessment
- Terminates when no longer required

Agentless NAC:

- Integrated with Active Directory
- Checks are made during login and logoff

- Can't be scheduled

Failing your assessment:

What happens when a posture fails:

- Too dangerous to be on network

Quarantine network, notify admin

Once resolved try again

Endpoint detection and response (EDR):

A different method of threat protection:

- Scale to meet the increasing number of threats

Detect a threat:

- Signatures aren't the only detection tool
- Behavioral analysis, machine learning, process monitoring
- Lightweight agent on the endpoint

Investigate the threat:

- Root cause analysis

Response to the threat:

- Isolate the system, quarantine the threat, rollback to previous config
- API driven, no user or technician intervention required

Extended Detection and Response (XDR):

An evolution of EDR:

- Improve missed detection, false positives, and long investigation times
- Attacks involve more than just the endpoint

Add network based detection:

- Investigate and respond to the network anomalies

Correlate endpoint, network and cloud data:

- Improve detection rates
- Simplify security event investigations

User behavior analytics:

XDR commonly includes behavior analytics:

- extend the scope of anomaly detection

Watch users, hosts, network traffic, data repositories, etc:

- Create a baseline or normal activity
- Requires data analysis over an extended period of time

Watch for anything unusual:

- Use a set of rules pattern matching etc

Real time detection of unusual activity:

- catch threat early